



UNIVERSITY OF
LEICESTER

School of Computing and Mathematical Sciences

CO7201 Individual Project

Preliminary Report

**Risk Modelling and Analysis for IT Systems using
Probabilistic Graph Rewriting Rules**

Neel Vinod Lad

nvl2@student.le.ac.uk

249025520

Project Supervisor : Prof. Reiko Heckel

Principal Marker : Dr. Victoria Wright

Word Count : 3140

Date : 27-06-2025

DECLARATION

All sentences or passages quoted in this report, or computer code of any form whatsoever used and/or submitted at any stages, which are taken from other people's work have been specifically acknowledged by clear citation of the source, specifying author, work, date and page(s). Any part of my own written work, or software coding, which is substantially based upon other people's work, is duly accompanied by clear citation of the source, specifying author, work, date and page(s). I understand that failure to do this amounts to plagiarism and will be considered grounds for failure in this module and the degree examination as a whole.

Name: Neel Vinod Lad

Date: 27-06-2025

Contents

1. Aims and Objectives	3
2. Requirements.....	4
3. Technical Specification	5
4. Requirements Evaluation Plan	6
5. Background Research and Reading list.....	8
6. Time-plan and Risk Plan.....	9
7. References	13
8. Appendix.....	14

1. Aims and Objectives

This study proposes a formal, model-driven framework for risk modeling and analysis in business IT systems using probabilistic graph rewriting rules. IT infrastructures are represented as typed, attributed multigraphs, while attack patterns are encoded as graph transformation rules. This approach enables systematic vulnerability detection, quantitative risk estimation, and informed decision-making for system administrators. The goal is to bridge the gap between theoretical security models and practical risk management, offering effective decision support for mitigating cyber risks in complex organizational settings.

Modern business IT systems are increasingly complex and interconnected, facing a rapidly evolving threat landscape. Traditional risk assessment methods are often checklist-based or domain-specific lacks adaptability and fail to capture the dynamic, context-sensitive nature of real-world systems [1][2]. System administrators struggle to identify vulnerabilities, quantify risks, and understand the cascading consequences of multi-stage cyberattacks. There is a growing need for formal, automated, and context-aware risk analysis methods that can evolve alongside technological and adversarial advances [1].

The proposed framework offers several key benefits. First, the concept graph transformation rules can be used to detect and manipulate recurring patterns in models, enabling automated analysis and refactoring [3], it supports automated vulnerability detection through formal graph pattern matching, minimizing manual effort. Second, by associating attack rates and probabilistic outcomes with graph rewriting rules, it enables quantitative risk assessment, estimating both the likelihood and impact of various attack scenarios [4]. Third, its model-driven design is customizable and extensible, allowing adaptation to diverse infrastructures and threat profiles. Lastly, system semantics are formalized using Continuous-Time Markov Decision Processes (CTMDPs), providing a rigorous basis for stochastic simulation, risk propagation, and scenario-based decision support [4][5].

Despite its advantages, this approach faces several challenges. Modeling large-scale IT systems as attributed graphs can lead to scalability and computational complexity, particularly in real-time contexts. Risk analysis accuracy depends on high-quality, up-to-date system data, which may be lacking in practice. Developing and maintaining comprehensive risk rules requires deep domain expertise and continuous updates to address emerging threats [2]. Technical integration with existing IT and security tools may also be challenging. Importantly, ensuring the interpretability and actionability of results is vital for practical adoption by system administrators.

2. Requirements

The following is a tentative requirement list segregated by importance for the Risk Modelling and Analysis for IT Systems using Probabilistic Graph Rewriting Rules.

2.1 Essential Requirements

- 2.1.1 **Foundational Literature and Tooling Review:** Before developing a prototype, it is essential to build a strong foundational understanding of graph-based modeling and transformation within the context of software engineering. This includes a solid grasp of the MITRE ATT&CK framework for identifying and categorizing adversarial behaviors, as well as hands-on familiarity with graph rewriting tools such as GROOVE for pattern matching and rule application. Additionally, background knowledge of Continuous-Time Markov Decision Processes (CTMDPs) and probabilistic model checking—using tools like PRISM—is crucial for accurately simulating attack propagation and analyzing risk over time. These foundational elements are critical to effectively designing and implementing the proposed risk modeling system.
- 2.1.2 **Typed Attributed Multigraph Representation:** The system must support modelling IT infrastructures as typed attributed multigraphs, including nodes (users, servers, devices, etc.), edges (relations), and attributes (e.g., *has_access_to*, *owns*, *runs_on*, *alerts* role).
- 2.1.3 **Formal Rule Specification Language:** There must be a machine-readable format (e.g., YAML, JSON) for defining graph rewriting rules with vulnerability patterns, attack rates, and probabilistic outcomes.
- 2.1.4 **Automated Graph Pattern Matching Engine:** The system must support matching rule patterns (LHS) against the business graph to detect vulnerabilities. Graph rewriting tool GROOVE provides such functionalities.
- 2.1.5 **Probabilistic Risk Analytics:** For each pattern match, the system must estimate risk using attack rates per year, outcome probabilities of attack, and costs to company.
- 2.1.6 **MITRE ATT&CK:** Risk rules must be grounded in real-world attack techniques (e.g., MITRE ATT&CK).
- 2.1.7 **Model Consistency Checking:** The system must validate that the graph and rules are consistent and compatible for matching

2.2 Recommended Requirements

- 2.2.1 **Graph Visualization:** Visual representation of the business graph and attack surface (e.g., using, GROOVE, PlantUML, or python matplotlib) should be useful.
- 2.2.2 **Modular Rule Organization:** Rules should be organized by tactics/techniques or attack phases for easier management and extensibility.

- 2.2.3 Scenario/What-if Analysis: Ability to modify the business graph or rules and re-run risk analytics for comparative studies should be consider.
- 2.2.4 Export to Model Checker: Ability to export the system model to tools like PRISM or STORM for formal CTMDP analysis should be implemented.
- 2.2.5 Continuous-Time Markov Decision Process (CTMDP) Integration: Formal semantics and simulation using CTMDP tools (e.g., PRISM, STORM) for advanced risk propagation analysis is desirable.

2.3 Optional Requirements

- 2.3.1 Automated Rule Extraction: Use of NLP or LLMs could assist in extracting risk rules from policy documents or threat intelligence feeds.
- 2.3.2 Interactive Dashboard: Web-based or GUI dashboard could provide an interactive exploration of the business graph and risk analytics.
- 2.3.3 OCL-like Constraints: Support for expressing and enforcing may provide advanced constraints on pattern matching.
- 2.3.4 Support for Mitigation and Defence Rules: The system might have the ability to model and simulate the effect of defensive controls (e.g., firewalls, EDR, user training) within the same framework.

3. Technical Specification

The following platforms and technologies have been identified as essential for study:

3.1 Risk Specification, Typed Attributed Multigraph, Business Graph Modelling:

- Language: JSON for machine-readable risk rule definitions processing rule files.

3.2 Consistency Check for Risk Specifications and Business graph with Metamodel:

- Language: Python, a simple script loads graphs and risk rules in JSON format to check their consistency among nodes, edges, attributes etc.

3.3 Pattern Matching:

- Platform: GROOVE (graph transformation tool).

3.4 Probabilistic Modelling and Simulation:

- Platforms: PRISM and STORM (probabilistic model checkers) for CTMDP-based simulation and analysis.

3.5 Visualization and Simulation:

- Platform: PlantUML for diagrammatic representation and Groove for simulation

3.6 Other Tools: Git for version control, and Microsoft Loop for collaborating with supervisor analysis and documentation.

3.7 Tools such as ChatGPT and GitHub Copilot were instrumental in supporting the development of high-level JSON schema structures and in-depth planning for foundational elements of the study. These include defining the metamodel, constructing the business and typed graphs, and preparing standardized, concise documentation formats. Their use facilitated early-stage design exploration, rapid prototyping, and consistent modeling practices throughout the study

4. Requirements Evaluation Plan

To rigorously assess the effectiveness, consistency and utility of this risk modelling and analysis, the following evaluation criteria are put in consideration for now:

Primary Evaluation Plans

1. Correctness of Risk rules with Business and Typed Multigraph:

The risk rules are derived based on the MITRE ATT&CK framework. In the initial development phase, approximately 17–18 rules have been drafted. These rules will be graphically visualized using PlantUML and later implemented in GROOVE for simulation and analysis. As the modeling progresses, each rule will undergo further refinement through research, community feedback from online forums, and consultations with industry experts. This iterative process aims to address challenges related to the practical adoption of the framework in real-world business environments.

2. Consistency of Risk Specifications and Business Graph with Typed graph (meta model):

A python script functions as a consistency checker to ensure that both the business graph and risk rules align with the definitions specified in the typed graph (metamodel). It loads the metamodel, business graph, and risk rules from JSON files, then extracts all valid node types, relation types, and permissible attributes. The script verifies that every node and relation in the business graph adheres to the defined types and attributes. It also checks that all references within the risk rules such as node types, attributes, and relations are properly defined in the metamodel. Any inconsistencies, including undefined types or attributes, are reported as errors; otherwise, the script confirms that all components are consistent. This validation step is critical for preventing schema mismatches and ensuring the integrity of the risk analysis process.

3. Performance and Scalability:

The system's computational efficiency will be evaluated based on processing time, memory usage, and the extent of state space exploration across business graphs of varying size and complexity using the GROOVE tool. All possible outcomes will be visualized to support analysis. Scalability will be assessed by determining the largest graph and rule set the system can effectively process within practical time and resource constraints.

4. Validation Against Analytical Benchmarks:

For small, controlled business graph scenarios, risk metrics (such as expected cost and compromise probability) will be calculated both manually and using the simulation tool. For example, if a rule specifies an attack rate (λ) and outcome probabilities, the expected number of successful attacks and their costs can be derived analytically using basic probability and Markov process theory [4]. The simulation results will be compared to these analytical values to verify correctness.

5. Synthetic Scenario Testing

Synthetic attack scenarios with known parameters and outcomes will be constructed. By running simulations on these scenarios, the computed risk metrics should match the expected results. For instance, if a single vulnerability has a 10% chance of leading to a \$10,000 loss, the expected cost should converge to \$1,000 over many simulations runs. This approach is widely used in the validation of probabilistic models [4].

5. Sensitivity Analysis

The sensitivity of risk metrics to changes in input parameters (attack rates, outcome probabilities, costs) will be systematically tested. The system should exhibit proportional and predictable changes in risk estimates when these parameters are varied. This helps ensure that the quantitative calculations are robust and logically consistent [6].

7. Comparison with Real-World Data

Where possible, simulation outputs will be compared with published incident statistics or case studies [1][2]. For example, if empirical data shows that phishing attacks result in compromise 5% of the time, the model's outputs for similar scenarios should align with this figure, validating the realism of the risk estimation.

8. Expert Review

Risk metrics and their interpretations will be reviewed by domain experts (e.g., cybersecurity professionals or academic supervisors) to assess whether the results are plausible, meaningful, and actionable for decision-making.

5. Background Research and Reading list

A foundational understanding of graph theory and graph transformation is essential for this study. Typed attributed multigraphs provide a flexible structure for modelling complex IT systems, where nodes and edges can represent diverse entities and relationships, and attributes encode contextual information. Graph pattern matching and rewriting rules enable the systematic detection and transformation of substructures, which is critical for modelling vulnerabilities and attacks. The challenge of subgraph isomorphism underpins the computational aspects of pattern matching [3][7].

In the domain of cybersecurity, risk modelling focuses on representing vulnerabilities, attack paths, and the propagation of threats within an organization's infrastructure. Frameworks such as MITRE ATT&CK and ENISA's Threat Landscape reports provide taxonomies and real-world data on adversary tactics, techniques, and procedures, supporting the development of realistic attack models and risk assessment methodologies. Attack graphs and kill chains are widely used to visualize and analyze potential attack scenarios and their impact [1][3].

Probabilistic modelling and model checking are crucial for quantifying risk in dynamic environments. Continuous-Time Markov Decision Processes (CTMDPs) allow the formalization of system states, transitions, and stochastic behaviors, enabling the analysis of risk propagation over time. Probabilistic model checkers such as PRISM and STORM facilitate the verification and simulation of these models, supporting rigorous evaluation of security properties and expected [4][5][8].

Risk quantification relies on metrics such as expected loss, attack rate, and likelihood estimation. Sensitivity analysis is employed to understand how changes in input parameters affect risk outcomes, ensuring the robustness of the model. The literature highlights the limitations of traditional, checklist-based risk management and advocates for quantitative, model-driven approaches that provide actionable insights [6][9].

A range of tools and platforms support this research, including networkx and Neo4j for graph modelling, GROOVE and Henshin for graph transformation, and PRISM and STORM for probabilistic model checking. Visualization tools such as Matplotlib, and the Neo4j Browser aid in interpreting and communicating results.

The literature demonstrates the value of graph-based security modelling, formal verification, and quantitative analytics in advancing risk assessment. Research on attack graphs [10] and the application of formal methods [4] underscore the need for systematic, automated, and adaptable risk analysis frameworks, as traditional approaches often fall short in complex, evolving IT environments [1].

6. Time-plan and Risk Plan

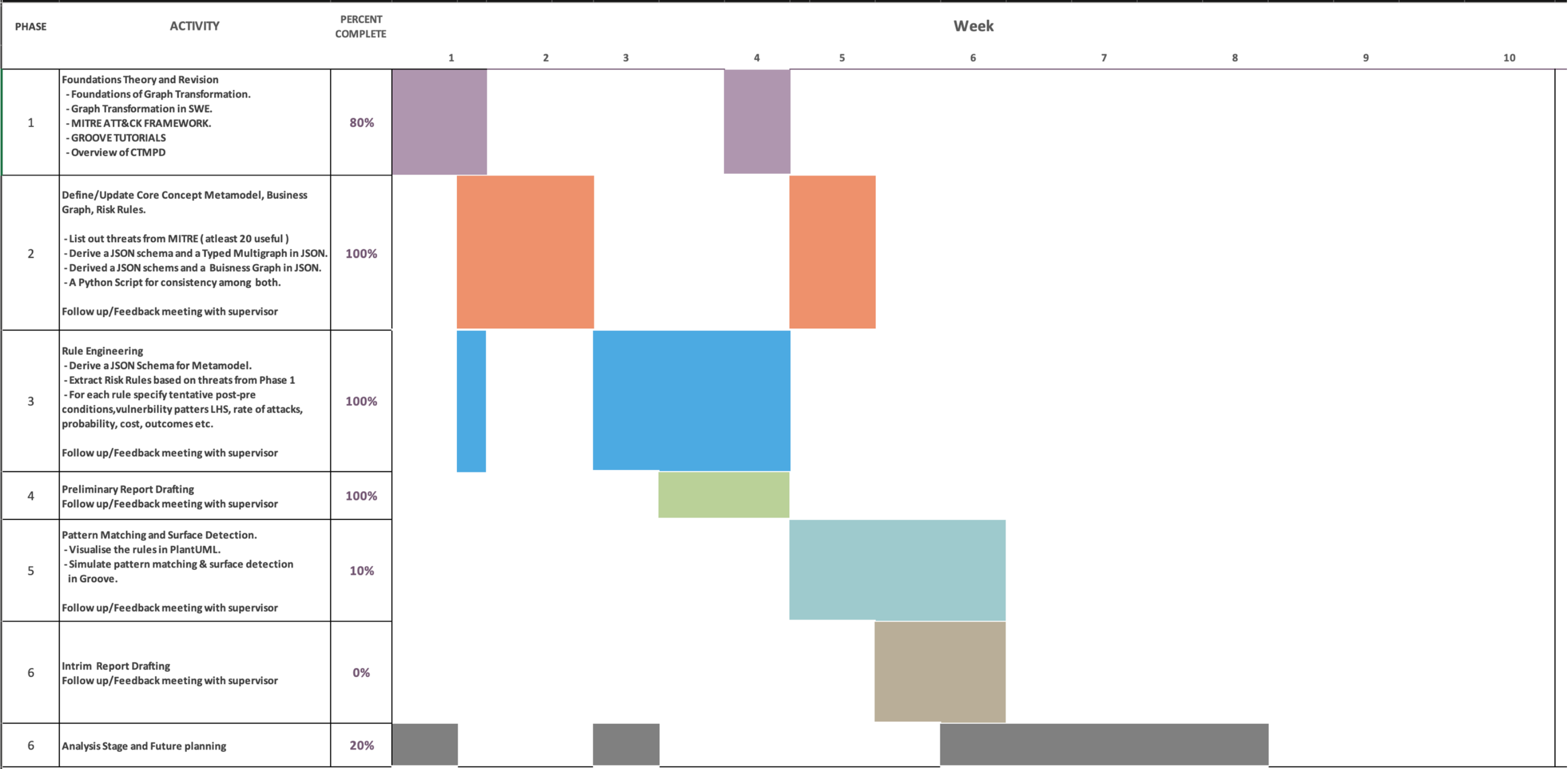


Figure 1: Estimated research and development time-plan for this study.

Phase Plan

Phase 1: Foundational Theory and Revision (Week 1–1.5)

In this initial phase before working with news technologies, understanding of core and foundational concepts are necessary. A solid grasp of graph theory and transformation is key to this study which will help in deriving Typed attributed multigraphs, flexibly model complex IT systems, with nodes, edges, and attributes capturing entities, relationships, and context. Graph pattern matching and rewriting enable structured detection and transformation of vulnerabilities. It also includes a review of the MITRE ATT&CK framework to understand real-world attack tactics [1][3]. Some working knowledge of Groove Tool would make for pattern matching and lastly an overview of Continuous-Time Markov Decision Processes (CTMDPs) to formalize semantics, risk propagation and scenario- decision support.

Phase 2: Core Modelling & Threat Analysis (Week 2-3)

Defining or update the core metamodel, business graph, and risk rules. Identifying at least 20 relevant threats from a legit source MITRE ATT&CK framework. Developing JSON schemas representations for both the typed multigraph and business graph, moving ahead deriving entire graph based on schema. Lastly, implementing a Python script to ensure consistency.

A weekly meeting with supervisor for feedback and planning.

Phase 3: Rule Engineering (Week 2.5-3)

Creating a JSON schema for the metamodel and extracting risk rules based on the identified threats in Phase 2. For each rule, specifying pre/post-conditions, vulnerability patterns (LHS), rate of attack per year, probabilities of occurring an attack, costs to company, outcomes of attack.

A weekly meeting with supervisor for feedback and planning

Phase 4: Preliminary Report Drafting (Week 3)

Preparing draft for the preliminary report, documenting progress and findings.

A weekly meeting with supervisor for feedback and planning

Phase 5: Pattern Matching & Surface Detection (estd. Week 4-6)

Visualizing risk rules using PlantUML and simulating pattern matching and surface detection in GROOVE.

A weekly meeting with supervisor for feedback and planning

Phase 6: Interim Report Drafting (Week 6)

Drafting the interim report, consolidating results and insights from earlier phases.

A weekly meeting with supervisor for feedback and planning

Phase 7: Simulation and Analysis (estd. Week 8–10)

In this phase defining the formal semantics of the risk model as a Continuous-Time Markov Decision Process (CTMDP). Business graphs represent system states, and transitions correspond to the application of attack rules. Attack rates determine transition timing, while probabilistic outcomes define branching behavior. Using tools like PRISM, a custom simulator, stochastic simulations will be conducted to evaluate risk propagation, time to compromise, and expected long-term costs under various scenarios.

Phase 8: Planning for achieving some Optional Requirements and further improvement in the existing phases.

Risk Plan

These incoming risk assessment till now are adopted can be enhanced through research and development process:

1. Risk Identification

- 1.1 **Data Quality and Consistency:** Inconsistencies between the business graph, risk rule specifications, and the typed graph (e.g., mismatched node types, attributes, or relations) may lead to incorrect pattern matching and analysis errors.
- 2.1 **Scalability and Computational Complexity:** Modelling and analyzing the entire IT system at once can result in high computational demands, making the process slow or infeasible for large infrastructures.
- 1.3 **Pattern Matching Errors:** Manual matching of risk rule patterns to the business graph is error-prone and time-consuming, increasing the risk of missed vulnerabilities or false positives.
- 1.4 **Tool Integration and Usability:** Jumping directly into advanced tools like GROOVE without proper preparation may lead to inefficiencies, steep learning curves, or misconfigurations.
- 1.5 **Visualization and Change Management:** Lack of clear visualization for rules and system structure can make it difficult to adapt to changes or communicate findings effectively.

2. Mitigation Strategies

- 2.1 **Modular Modelling:** Instead of modelling the entire IT system at once, breaking down the infrastructure into smaller, manageable modules or domains. This modular approach reduces computational complexity and allows for focused, scalable analysis.
- 2.2 **Automated Consistency Checking:** Developing a dynamic program to automatically compare nodes, attributes, relations, and sources across the business graph, risk rule specs, and typed graph. This tool will highlight missing or incorrect parameters, ensure consistency and reducing manual effort.
- 2.3 **Incremental Visualization:** Before using advanced pattern matching tools like GROOVE, visualizing risk rules and system structure using adaptable tools such as PlantUML. This step makes it easier to adapt to changes, verify correctness, and set a solid foundation for subsequent analysis.
- 2.4 **Phased Tool Adoption:** Gradually introducing advanced tools, starting with visualization and simple pattern matching, before moving to full automation and simulation. This reduces the risk of tool-related errors and allows for smoother integration.
- 2.5 **Continuous Review and Adaptation:** Regularly reviewing modelling choices, rule definitions, and analysis outputs, incorporating feedback and adapting to new requirements or threats as needed.

7. References

- [1] European Union Agency for Cybersecurity, *Space threat landscape 2025*, ENISA, Luxembourg, Mar. 26, 2025 <https://www.enisa.europa.eu/publications/enisa-space-threat-landscape-2025>
- [2] MITRE ATT&CK. (2025) <https://attack.mitre.org/>
- [3] Heckel, R., Taentzer, G. (2020). *Analysis and Improvement of Graph Transformation Systems*. In: *Graph Transformation for Software Engineers*. Springer, Cham. https://doi.org/10.1007/978-3-030-43916-3_4
- [4] Kwiatkowska, M., Norman, G., Parker, D. (2011). *PRISM 4.0: Verification of Probabilistic Real-Time Systems*. In: Gopalakrishnan, G., Qadeer, S. (eds) *Computer Aided Verification. CAV 2011. Lecture Notes in Computer Science*, vol 6806. Springer, Berlin, Heidelberg. https://doi.org/10.1007/978-3-642-22110-1_47
- [5] PRISM Model Checker <https://www.prismmodelchecker.org/publ-lists.php>
- [6] Saltelli, A., Ratto, M., Andres, T., Campolongo, F., Cariboni, J., Gatelli, D., & Tarantola, S. (2008). *Global sensitivity analysis: The primer*. John Wiley & Sons <https://doi.org/10.1002/9780470725184.ch6>
- [7] Ehrig, Hartmut & Ehrig, Karsten & Golas, Ulrike & Taentzer, Gabriele. (2006). *Fundamentals of Algebraic Graph Transformation* <https://doi.org/10.1007/3-540-31188-2>
- [8] STORM model checker: <https://www.stormchecker.org/>
- [9] Hubbard, Douglas. (2009). *Failure of Risk Management: Why It's Broken and How to Fix It*. <https://doi.org/10.1002/9781119521914>.
- [10] Sheyner, Oleg & Haines, Joshua & Jha, Somesh & Lippmann, Richard & Wing, Jeannette. (2002). *Automated Generation and Analysis of Attack Graphs*. *Proceedings of the IEEE Computer Society Symposium on Research in Security and Privacy*. <https://doi.org/10.1109/SECPRI.2002.1004377>.

8. Appendix

Risk Rule Summary

ID	Title	MITRE ATT&CK ID	Tags	Attack Definition (Short)	Key Pattern (LHS) Summary	Attack Rate (λ)	Scope
RISK001	Phishing Attack on Active Email Account	T1566.001	initial-access, phishing	Attacker sends phishing email to user to steal credentials.	Active EmailAccount owned by User	5/year	per active email account
RISK002	Privilege Escalation via Writable File	T1548	privilege-escalation	User exploits writable file to gain higher privileges.	File (write), User can_write File	2/year	per vulnerable file
RISK003	Credential Dumping from Compromised Host	T1003	credential-access	Attacker extracts credentials from a compromised host.	Compromised Host, admin Credentials stored_on	4/year	per compromised host
RISK004	Remote Service Exploitation (RDP)	T1021.001	lateral-movement	Attacker exploits exposed RDP service for lateral movement.	Exposed RDP Service, Host runs Service	3/year	per exposed RDP service
RISK005	Lateral Movement via Pass-the-Hash	T1550.002	lateral-movement	Attacker uses stolen NTLM hashes to move laterally.	Stolen CredentialHash, Host accepts_ntlm	4/year	per valid NTLM hash
RISK006	Data Exfiltration via Cloud Storage	T1537	exfiltration	Attacker exfiltrates sensitive data to cloud storage.	File (high sensitivity), Attacker has_access_to	2/year	per attacker with file access
RISK007	Abuse of Trusted Relationships	T1210	lateral-movement	Attacker abuses trust between hosts for lateral access.	Compromised Host trusts another Host	2/year	per trusted path
RISK008	Malicious Use of Remote Admin Tools	T1569.002	execution, lateral-movement	Attacker uses remote admin tools for unauthorized actions.	Host accepts_remote_exec, admin Credentials	3/year	per admin cred & host
RISK009	Exploitation of Public-Facing Application	T1190	initial-access	Attacker exploits a vulnerable public-facing application.	Exposed & vulnerable Application	4/year	per vulnerable app
RISK010	Unauthorized Script Execution on Server	T1059	execution	Attacker executes unauthorized/malicious scripts on server.	Malicious Script deployed, Server runs Script	5/year	per server
RISK011	Exploitation via Malicious USB Device	T1200	initial-access, execution	Attacker uses a malicious USB device to compromise a host.	Malicious USBDevice inserted into Host	2/year	per inserted USB
RISK012	DNS Tunneling for Covert Communication	T1071.004	command-and-control, exfil	Attacker uses DNS tunneling for covert communication or exfiltration.	Compromised Host, active DNSChannel	2/year	per compromised host

ID	Title	MITRE ATT&CK ID	Tags	Attack Definition (Short)	Key Pattern (LHS) Summary	Attack Rate (λ)	Scope
RISK013	Compromise via SaaS Credential Stuffing	T1110.004	initial-access, cloud	Attacker uses leaked credentials to access SaaS accounts.	SaaSAccount (unprotected), reused Credentials	6/year	per leaked credential set
RISK014	Insider Copying Confidential Files	T1537	exfiltration, insider-threat	Insider copies high-sensitivity files to external storage or cloud.	User (internal), File (high sensitivity)	3/year	per user with file access
RISK015	Persistence via Scheduled Task Creation	T1053	persistence	Attacker creates scheduled tasks for persistence on compromised host.	Compromised Host, Attacker has_access_to	3/year	per compromised host
RISK016	Defense Evasion by Disabling Security Tools	T1562.001	defense-evasion	Attacker disables security tools to avoid detection.	Compromised Host, active SecurityTool	2/year	per compromised host
RISK017	Persistence via Registry Run Keys	T1547.001	persistence, windows	Attacker adds malicious registry run keys for persistence on Windows hosts.	Host (Windows, compromised)	2/year	per compromised Windows host

Table 1 : Tentative Risk Rules [2]